UNIVERSITY OF AGDER



IKT214-G Security and IoT

Threat Modeling

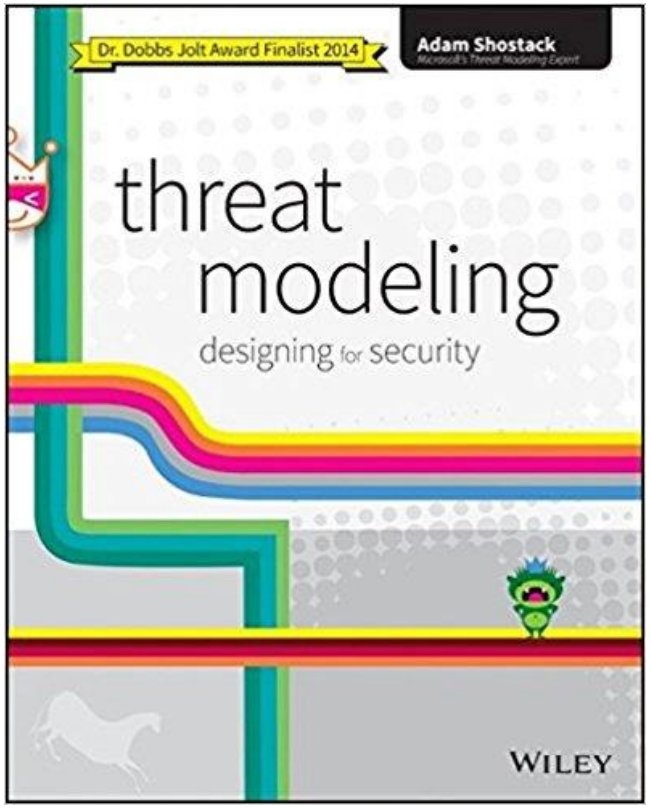
Presented By: Dr. Debasish Ghose

Based on the slides of Prof. Geir M. Køien



Threat Modeling

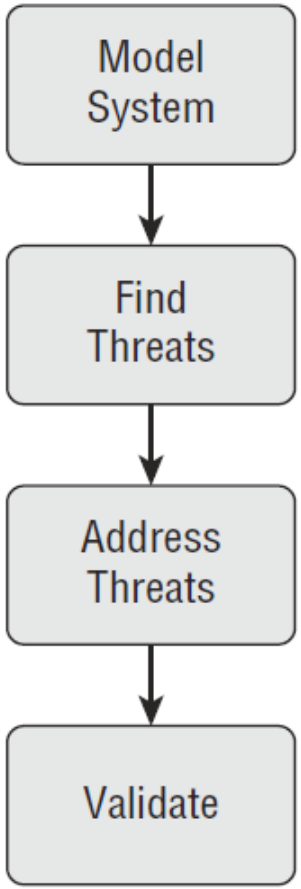
1. Dive In and Threat Model
2. Strategies for Threat Modeling
3. STRIDE
4. Attack Trees
5. Attack Libraries
6. Privacy Tools
7. Processing and Managing Threats
8. Defensive Tactics and Technologies
9. Trade-offs When Addressing Threats
10. Validating that Threats are Addressed
11. Threat Modeling Tools
12. Requirements Cookbook
13. Web and Cloud Threats
14. Accountability and Identity
15. Human Factors and Usability
16. Threats to Cryptosystems
17. Bringing Threat Modeling to Your Organization
18. Experimental Approaches
19. Architecting for Success



Threat Modeling

- **The overall process**

1. Model the system you're building, deploying, or changing. Focus on components, trust boundaries, etc.
2. Identify threats using that model.
3. Address the threats. Prevent, remove, mitigate, …
4. Validate your work for completeness and effectiveness. There may be omissions and residual threats still present. Potentially, there may even be new threats due to the actions in 3 (the addressing).



Threat Modeling

- **Key Questions**

1. **What are you "building"?**
   - Software, hardware, integration, infrastructure, deployment,

2. **What can go wrong?**
   - Focus on security (but other errors can trigger security breaks)

3. **What should you do about those things that can go wrong?**
   - Use STRIDE approach when can. Redesign when necessary. Apply security controls. Prevent & mitigate.

4. **Did you do a decent job of analysis**
   - Were are threats adequately addressed? Any omissions?
   - Cost-benefit (efficiency)
   - Completeness & consistency (future-proof is often important)

Threat Modeling

- **What are you "building"?**
  - **Use visual cues (diagrams are a good tool)**
  - **Example: Simple Web App**
    - Web browser and Web server
    - Business logic (application specific)
    - Database

Interfaces & boundaries

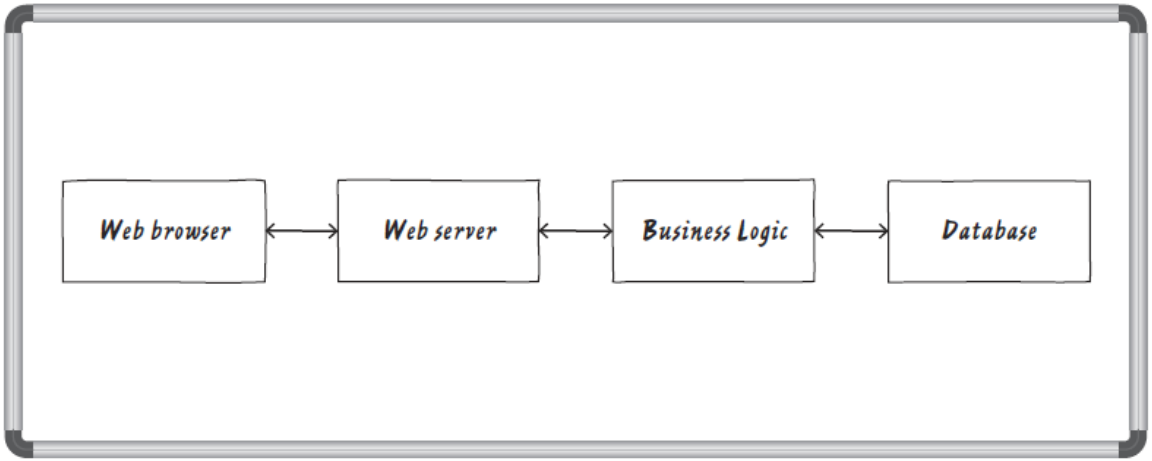


Figure 1-1: A whiteboard diagram

Threat Modeling

- **What are you "building"?**
  - **Trust boundaries (interfaces)**
    - Interfaces and boundaries (physical and logical) often define trust boundaries
    - With change in trust (increased uncertainty) there is a need for security controls
    - **Different kinds of boundaries:**
      - Login accounts
      - Network interfaces
      - Different physical computers
      - Virtual machines
      - Organizational boundaries
      - Almost anywhere you can argue for different privileges

Threat Modeling

- **What are you "building"?**
  - **Trust boundaries**
  - **Company view:**
    - Web browser is on the outside (not trusted a priori)
    - Web server and business logic is contained within the corporate data center
    - Database is hosted off-site (possibly outsourced)

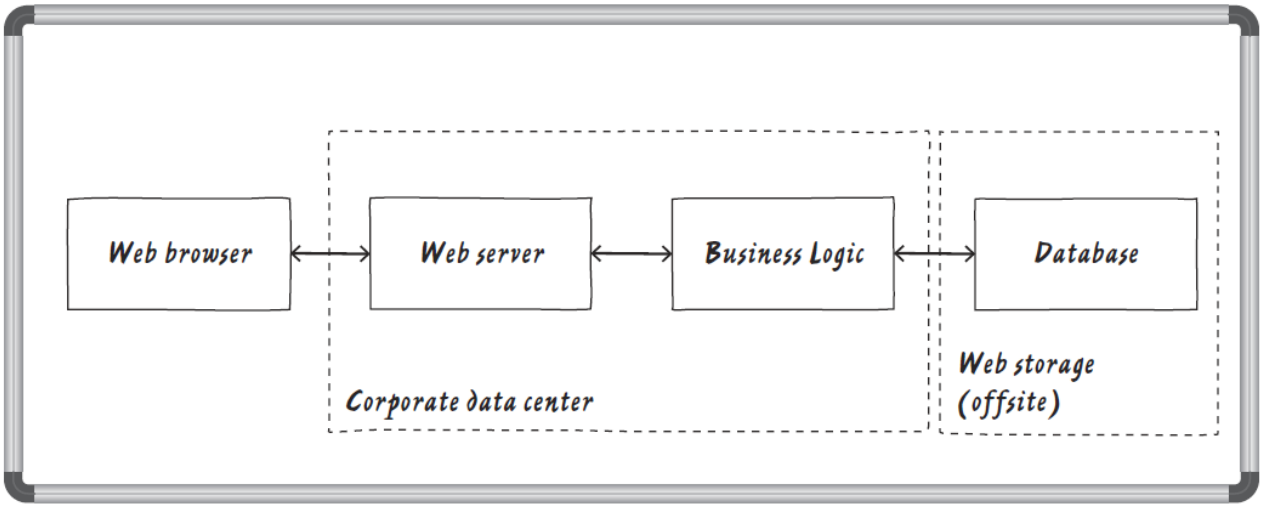


Figure 1-2: Trust boundaries added to a whiteboard diagram

Threat Modeling

- **What are you "building"?**
  - **Trust boundaries**
  - **Keeping track**
    - Number the boxes (processes)
    - Number interfaces
    - Trust zones (called trust boundaries in the book) should also be identifiable

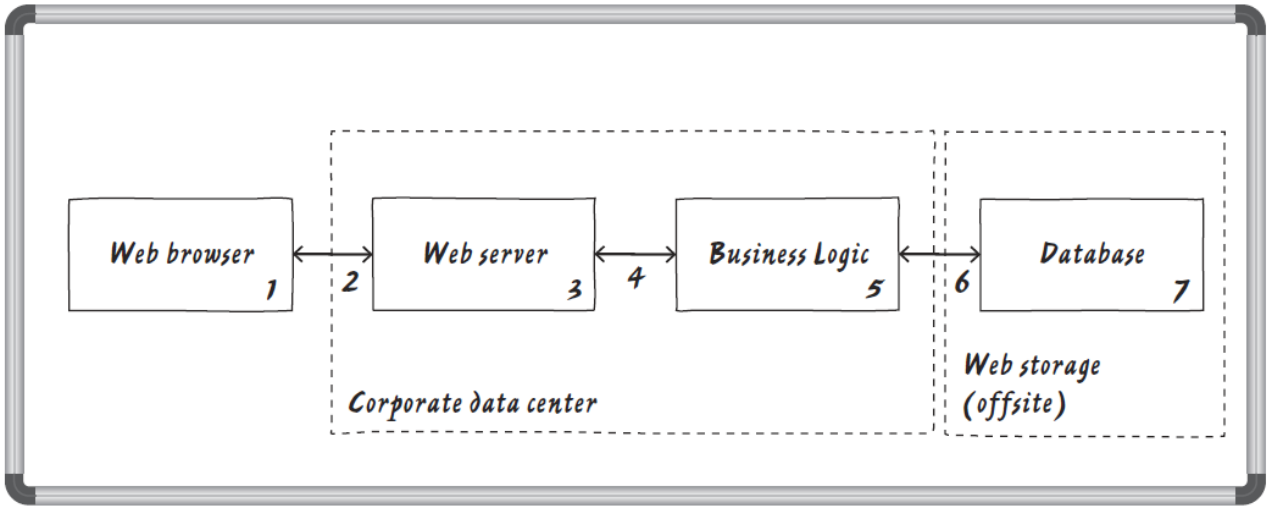


Figure 1-3: Numbers and trust boundaries added to a whiteboard diagram

Threat Modeling

- **What can go wrong?**

  - **Use STRIDE approach to find threats**

  - **S**poofing – pretending to be something/someone (masquerade/impersonation)
  - **T**ampering – illicit (unauthorized) modification of something (even deletion)
  - **R**epudiation – claiming you didn't do something (here: wrongful claim)
  - **I**nformation Disclosure – illicit (unauthorized) information exposure
  - **D**enial of Services – preventing legitimate access to resources
  - **E**levation of Privilege – access to resources you shouldn't have had access to

Threat Modeling

- **What can go wrong?**
  - **S**poofing (identity and authentication)
    - Someone might pretend to be another customer (web browser)
    - Someone might also pretend to be your website
      - The webserver should be identifiable (TLS and proper certificates)
  - **T**ampering (data integrity / system integrity / authorization)
    - Someone might tamper with the data in your back-end (database)
    - Someone might tamper with the data in transit between datacenters
    - A programmer might make a mistake ...
    - An angry programmer might add a coupon code “PayBobMore” that offers a 20 percent discount on all goods sold.

Threat Modeling

- **What can go wrong?**
  - **R**epudiation (logging, auditing , etc.)
    - Someone might deny placing an order – or deny receiving the item
    - There may be an error in the database inventory
      - Mismatch: no item provided, billing still occurred
    - Logs must be reliable and protected
  - **I**nformation Disclosure (data confidentiality / authorization)
    - Who should be able to see the transactions in the database?
    - Who should be able to see the business logic?

Threat Modeling

- **What can go wrong?**
  - **D**enial of Services (availability, access control)
    - Sufficient capacity – in the whole service chain
    - Admission control / access control
    - Resilience against DoS attacks (when practical)
      - "Symmetry in effort" – make sure the intruder must do work
  - **E**levation of privilege (access control / authorization)
    - Confused deputy
    - Inconsistent access control
    - Inconsistent access control policy

Threat Modeling

- **Addressing the threats**
  - **Mitigation**
    - Making it harder to take advantage of a threat
    - Reducing the impact of the threat
    - Using passwords to control login mitigates the threat of spoofing
    - Adding password controls that enforce complexity/expiration
  - **Elimination**
    - Elimination of features and functionality
    - Elimination of attack surface (reduce exposure)
  - **Transferring threats**
    - Let someone else handle the threats (and functionality)
    - Let OS handle login (normally a good strategy)
    - Let user take risk (sometimes appropriate)
  - **Accepting the risk**

Threat Modeling

Table 1-1: Addressing Spoofing Threats

THREAT TARGET	MITIGATION STRATEGY	MITIGATION TECHNIQUE
Spoofing a person	Identification and authentication (usernames and something you know/have/are)	Usernames, real names, or other identifiers: ❖ Passwords ❖ Tokens ❖ Biometrics Enrollment/maintenance/expiry
Spoofing a "file" on disk	Leverage the OS	❖ Full paths ❖ Checking ACLs ❖ Ensuring that pipes are created properly
	Cryptographic authenticators	Digital signatures or authenticators
Spoofing a network address	Cryptographic	❖ DNSSEC ❖ HTTPS/SSL ❖ IPsec
Spoofing a program in memory	Leverage the OS	Many modern operating systems have some form of application identifier that the OS will enforce.

Threat Modeling

Table 1-2: Addressing Tampering Threats

THREAT TARGET	MITIGATION STRATEGY	MITIGATION TECHNIQUE
Tampering with a file	Operating system	ACLs
	Cryptographic	❖ Digital Signatures ❖ Keyed MAC
Racing to create a file (tampering with the file system)	Using a directory that's protected from arbitrary user tampering	ACLs Using private directory structures (Randomizing your file names just makes it annoying to execute the attack.)
Tampering with a network packet	Cryptographic	❖ HTTPS/SSL ❖ IPsec
	Anti-pattern	Network isolation (See note on network isolation anti-pattern.)

Threat Modeling

Table 1-3: Addressing Repudiation Threats

THREAT TARGET	MITIGATION STRATEGY	MITIGATION TECHNIQUE
No logs means you can't prove anything.	Log	Be sure to log all the security-relevant information.
Logs come under attack	Protect your logs.	❖ Send over the network. ❖ ACL
Logs as a channel for attack	Tightly specified logs	Documenting log design early in the development process

Threat Modeling

Table 1-4: Addressing Information Disclosure Threats

THREAT TARGET	MITIGATION STRATEGY	MITIGATION TECHNIQUE
Network monitoring	Encryption	❖ HTTPS/SSL ❖ IPsec
Directory or filename (for example `layoff-letters/adamshostack.docx`)	Leverage the OS.	ACLs
File contents	Leverage the OS.	ACLS
	Cryptography	File encryption such as PGP, disk encryption (FileVault, BitLocker)
API information disclosure	Design	Careful design control Consider pass by reference or value.

Threat Modeling

Table 1-5: Addressing Denial of Service Threats

THREAT TARGET	MITIGATION STRATEGY	MITIGATION TECHNIQUE
Network flooding	Look for exhaustible resources.	❖ Elastic resources ❖ Work to ensure attacker resource consumption is as high as or higher than yours.
		Network ACLS
Program resources	Careful design	Elastic resource management, proof of work
	Avoid multipliers.	Look for places where attackers can multiply CPU consumption on your end with minimal effort on their end: Do something to require work or enable distinguishing attackers, such as client does crypto first or login before large work factors (of course, that can't mean that logins are unencrypted).
System resources	Leverage the OS.	Use OS settings.

Threat Modeling

Table 1-6: Addressing Elevation of Privilege Threats

THREAT TARGET	MITIGATION STRATEGY	MITIGATION TECHNIQUE
Data/code confusion	Use tools and architectures that separate data and code.	❖ Prepared statements or stored procedures in SQL ❖ Clear separators with canonical forms ❖ Late validation that data is what the next function expects
Control flow/ memory corruption attacks	Use a type-safe language.	Writing code in a type-safe language protects against entire classes of attack.
	Leverage the OS for memory protection.	Most modern operating systems have memory-protection facilities.
	Use the sandbox.	❖ Modern operating systems support sandboxing in various ways (AppArmor on Linux, AppContainer or the MOICE pattern on Windows, Sandboxlib on Mac OS). ❖ Don't run as the "nobody" account, create a new one for each app. Postfix and QMail are examples of the good pattern of one account per function.
Command injection attacks	Be careful.	❖ Validate that your input is the size and form you expect. ❖ Don't sanitize. Log and then throw it away if it's weird.

Threat Modeling

Checking the model

- **Is it complete ?**
  - Does it cover every aspect?
  - Complete enough?
  - Maybe it needs updating?
- **Accurate?**
  - Is the coverage precise enough?
  - Maybe it needs updating
- **Security decision**
  - Does the model reflect the security decisions (security controls / policy / etc)
- **Next version?**